

DETECTION ENGINEERING & ALERT TRIAGE

SOC Triage Playbook

A lightweight runbook for investigating, classifying, documenting, and escalating Wazuh security alerts.

1. Purpose

This triage playbook provides a consistent process for investigating security alerts generated by the Wazuh SIEM. It guides the analyst through initial validation, evidence collection, severity assessment, disposition, and escalation or closure.

The objective is to ensure that alerts are handled consistently and that every disposition is supported by observable evidence.

2. Scope

This playbook applies to the custom detections developed for this project:

Detection	MITRE ATT&CK	Endpoint
Suspicious PowerShell	T1059.001	Windows
Encoded PowerShell	T1059.001	Windows
Windows Command Shell	T1059.003	Windows
Scheduled Task	T1053.005	Windows
SSH Password Guessing	T1110.001	Ubuntu

3. Triage Workflow

1. Identify: Record timestamp, host, user, rule ID, rule description, and source IP where applicable.

2. Validate: Confirm that the alert corresponds to the activity described by the detection rule.

3. Investigate: Review command line, process, parent process, user, network activity, timeline, and related alerts.

4. Establish Context: Determine whether the activity is expected for the user, host, and environment.

- 5. Assign Severity:** Use the Low, Medium, High, or Critical definitions in this playbook.
- 6. Determine Disposition:** Classify the alert as malicious, suspicious, benign, false positive, or requiring further investigation.
- 7. Escalate or Close:** Escalate when risk or evidence warrants it; otherwise close with a documented reason.
- 8. Record Findings:** Document evidence, reasoning, disposition, and action taken.

4. Initial Alert Information

At minimum, record the following information when an alert is received:

Field	Purpose
Timestamp	When the activity occurred
Host / Agent	Which endpoint generated the alert
Rule ID	Which detection triggered
Rule Description	What behavior was detected
Initial Severity	Initial risk assessment
User / Account	Identity associated with the activity
Source IP	Relevant for authentication/network alerts
Command Line	What was executed
Parent Process	What launched the process
Related Alerts	Other events around the same time

5. Investigation Checklist

- Host — Is this the expected endpoint for the activity?
- User — Is the account authorized to perform the activity? Is it privileged?
- Process — What process executed? What were its parent and child processes?

- Command — What exactly was executed? Is it encoded, obfuscated, or otherwise unusual?
- Timing — Did the event occur during expected work or maintenance activity?
- Network — Is there a relevant source/destination IP, port, or connection?
- Timeline — What happened immediately before and after the alert?
- Correlation — Are there other detections involving the same host, user, or time period?
- Context — Is there a legitimate explanation for the behavior?

6. Severity Classification

Severity	Definition	Typical Indicators	Typical Action
Low	Limited security significance or likely benign activity	Expected administration; isolated weak indicator	Close / document
Medium	Suspicious activity requiring investigation	Unusual PowerShell; isolated authentication anomaly	Investigate
High	Strong indication of malicious behavior	Encoded execution; credential attack; suspicious persistence	Escalate when supported
Critical	Confirmed or highly probable compromise with significant impact	Active compromise; successful credential compromise; lateral	Immediate escalation

		movement	
--	--	----------	--

7. Disposition Categories

Disposition	Meaning	Typical Action
True Positive — Malicious	Evidence supports malicious activity	Escalate
True Positive — Suspicious	Detection is valid and suspicious, but compromise is not confirmed	Continue investigation or escalate
Benign / Expected Activity	Activity is legitimate and expected	Close with justification
False Positive	Detection incorrectly identified legitimate behavior	Close; consider tuning if recurring
Requires Further Investigation	Evidence is insufficient for a confident classification	Collect more evidence or escalate

8. Detection-Specific Triage Guidance

Detection	Check	Suspicious Indicators	Benign Indicators
Suspicious PowerShell	User, command line, parent/child process, network activity	Execution-policy bypass; unusual parent; download/execute behavior	Authorized administrator script or maintenance
Encoded PowerShell	Command content, user, parent process,	Obfuscation; encoded command;	Known enterprise automation/security

	network destination	download; credential access; persistence	tooling
Windows Command Shell	cmd.exe command line, parent process, user	Unexpected cmd.exe; suspicious commands; chained execution	Normal administrative or diagnostic commands
Scheduled Task	Task name, creator, command, path, user	Random name; user-writable script/executable; unusual creator	Known application task or authorized maintenance
SSH Password Guessing	Source IP, usernames, frequency, subsequent login	Repeated failures; multiple usernames; unexpected source; later success	Known user mistyping credentials or authorized testing

8.1 Escalation Triggers by Detection

- PowerShell: suspicious command execution with an unusual parent process, unknown user, or related malicious indicators.
- Encoded PowerShell: encoded/obfuscated execution without a legitimate explanation, especially with network activity or persistence.
- Windows Command Shell: suspicious commands, unusual parent process, or correlation with other detections.
- Scheduled Task: unknown creator, suspicious script/executable, unusual task name/path, or evidence of persistence.
- SSH Password Guessing: repeated attacks, multiple targeted usernames, privileged-account targeting, or a successful login following failures.

9. Escalation Criteria

- There is evidence of malicious execution.
- Multiple suspicious detections correlate on the same endpoint.
- Credential attacks are repeated or appear successful.
- A persistence mechanism is created or modified suspiciously.
- Encoded or obfuscated commands execute without a legitimate explanation.
- Suspicious activity involves an administrative account.
- There is evidence of lateral movement.
- A critical system may be affected.
- The analyst cannot confidently establish that the activity is legitimate and the potential impact is significant.

10. Closure Criteria

- The activity is confirmed legitimate.
- The activity is an expected administrative or system operation.
- The detection is determined to be a false positive.
- Investigation finds no supporting indicators of malicious activity.
- The alert has been sufficiently investigated and the findings are documented.

Every closed alert must contain a concise justification. Example: “Closed as benign. The PowerShell command was executed by an authorized administrator during scheduled maintenance. No suspicious child processes, network activity, or related alerts were observed.”

11. Analyst Triage Record

Each investigated alert should be recorded using the following structure:

Field	Analyst Entry
Alert ID	

Timestamp	
Host / Agent	
Rule ID	
Rule Description	
Initial Severity	
Observed Evidence	1. 2. 3.
Investigation	1. 2. 3.
Final Severity	
Disposition	
Reasoning	
Action	

12. Analyst Decision Summary

1. Is the alert valid?
2. What behavior actually triggered it?
3. Who performed the activity and on which host?
4. Is the activity expected?
5. Are there suspicious indicators or related alerts?
6. What is the potential impact?
7. What severity is justified by the evidence?
8. Should the alert be closed, investigated further, or escalated?
9. Has the reasoning been documented?

13. Phase 4 Completion Criteria

- Triage playbook / runbook completed.
- Severity tiers defined.
- Escalation and closure criteria defined.
- Practice alert batch completed.
- Each practice alert has a documented disposition and reasoning.
- Relevant Wazuh screenshots are captured as investigation evidence.

SOC CHECKPOINT

Triage Runbook